

CSW Posture Brief — acme

One-page board update generated 2026-05-01T18:30:00Z. Source: live evidence bundle from <https://csw.acme-demo.local>.

Posture score

75 / 100 (C)

Component	Score	What it means
Visibility	24 / 25	4612/4820 workloads reporting (95.7% agent coverage).
Segmentation	18 / 30	312 policies, 248 in enforce mode (79%), 41 absolute (13%).
Hygiene	12 / 20	7 critical, 64 high CVEs detected on workloads.
Operations	13 / 15	24 enforcement alerts in last 24h.
Compliance	8 / 10	21/25 controls marked 'met' across 4 frameworks.

What's working (5)

- **Agent coverage at 95.7%.** Strong agent coverage means flow analytics, ADM recommendations, and policy enforcement are operating on the real estate, not a sample. *Reinforces:* HIPAA (2); PCI-DSS (1); NIST-800-53 (2); DORA (2).
- **312 policies authored.** A populated policy library indicates segmentation is past initial discovery and into active design. *Reinforces:* HIPAA (2); PCI-DSS (3); NIST-800-53 (4); DORA (1).
- **79% of policies in enforce mode.** Enforcement-mode policies are the difference between an audit narrative and a control. This ratio is the single best evidence the program is operational. *Reinforces:* HIPAA (2); PCI-DSS (3); NIST-800-53 (4); DORA (1).
- **47 scopes defined.** A scope hierarchy this deep means the segmentation model reflects organisational reality - prerequisite for least-privilege at scale. *Reinforces:* HIPAA (2); PCI-DSS (1); NIST-800-53 (2); DORA (2).
- **Evidence collected for 4 frameworks.** Re-using a single set of CSW evidence across multiple frameworks is the headline value proposition - this tenant is realising it. *Reinforces:* HIPAA (6); PCI-DSS (5); NIST-800-53 (7); DORA (3).

Where to focus next (4)

Compliance reach. Addressing the items below would help close ~7 **not-yet-met controls** across **4 frameworks** (HIPAA, NIST-800-53, PCI-DSS, DORA). The "Affects" column lists the framework and the count of controls per row.

#	Risk	Category	Impact	Affects
1	Few absolute policies in place — Absolute policies are the right tool for crown-jewel isolation (PHI, cardholder data, regulated systems). Their absence indicates the segmentation strategy is still permissive-by-default.	segmentation	+6 pts	HIPAA (1); NIST-800-53 (1)
2	64 policies remain in monitor mode — Monitor-mode policies generate evidence but do not block lateral movement. Promoting reviewed policies to enforce directly improves the segmentation score	segmentation	+3 pts	HIPAA (1); NIST-800-53 (1)

#	Risk	Category	Impact	Affects
3	component. 7 critical CVEs on workloads — CSW correlates package CVEs to running processes. Each critical CVE on an internet-reachable workload is a candidate for escalation to patching or compensating policy.	hygiene	+3 pts	PCI-DSS (1); DORA (1)
4	208 workloads without an agent — Workloads outside agent coverage are invisible to flow analytics, ADM, and policy enforcement. Closing this gap unlocks visibility-driven controls in every framework.	visibility	+1 pts	PCI-DSS (1)

30-day plan

Wk	Action	Owner
1	Close agent-coverage gap. Identify the 208 workloads without an agent. Triage into: (a) deploy now, (b) excluded by policy, (c) decommission. Track in a single ticket; aim for 95%+ coverage.	Platform Engineering
2	Author absolute policies for crown jewels. Identify the top 3 crown-jewel scopes (databases of regulated data, payment systems, PHI stores). Draft absolute policies that take precedence over inherited rules.	Security Architecture
3	Promote vetted policies to enforce mode. Run the 30-day flow review on monitor-mode policies for top 3 scopes. Promote those with no false-positive flow violations to enforce.	Security Operations
4	Address top critical CVEs. Pull the CSW vulnerability dashboard, sort by internet exposure + severity, dispatch top 10 to patching or compensating-policy workstreams.	Vulnerability Management
5	Refresh evidence and report. Re-run csw-insights against the tenant. Compare posture score to baseline; share delta with steering committee.	Compliance / GRC

Compliance posture across frameworks

Framework	Controls evaluated	Met	Coverage
HIPAA	7	6	86%
PCI-DSS	6	5	83%
NIST-800-53	8	7	88%
DORA	4	3	75%

Notes for the board pack

- **Source of truth.** Every number above is traceable to the underlying evidence bundle (evidence/acme-2026-05-01.json) signed at collection time. Auditors get the bundle; the board gets this page.
- **Cadence.** Re-running `csw-insights` weekly produces the trend line; the recommended cadence for board updates is monthly.
- **What this is not.** A posture score is a management tool, not a compliance attestation. Refer to the framework runbooks in `CSW-Compliance-Mapping` for control-by-control evidence.